ENTERPRISE RANSOMWARE INCIDENT RESPONSE & RISK ANALYTICS CASE STUDY

Simulated SOC Investigation, Business Risk Assessment and Cybersecurity Resilience Analysis

Case Study Organisation: NovaMart Global
Scenario Date: 14 March 2026
Project Type: Educational Cybersecurity and Business Risk Analytics Case Study

---

CASE STUDY DISCLAIMER

This project is a simulated cybersecurity incident response and business risk analysis case study created for educational, analytical and portfolio development purposes.

NovaMart Global, its organisational structure, infrastructure, employees, attack scenario, security alerts and operational details are hypothetical. They are designed to demonstrate:

- Cybersecurity risk assessment methodologies.
- SIEM-based threat detection and investigation concepts.
- Incident classification and response workflows.
- Business impact analysis.
- Enterprise cybersecurity governance.
- Risk mitigation and organisational resilience.

References to security technologies such as Splunk Enterprise, Wazuh and FortiSIEM describe their proposed roles within the hypothetical scenario. This report does not claim that these tools were deployed in a live environment or that real security telemetry was collected.

No actual security breach, financial loss, data exposure or incident investigation is claimed.

EXECUTIVE SUMMARY

This case study examines a hypothetical ransomware incident affecting NovaMart Global, a fictional multinational retail and e-commerce organisation operating across North America, Europe and the Asia-Pacific region.

The simulated incident takes place on 14 March 2026 and begins when an employee in the Finance department opens a malicious invoice attachment. The scenario then progresses through suspicious PowerShell execution, possible credential compromise, privilege escalation, lateral movement, suspicious outbound communication and ransomware-related file encryption.

The hypothetical Security Operations Center (SOC) identifies several warning indicators, including unusual command execution, repeated authentication failures, suspicious network communication and high-volume file modifications. Security monitoring concepts using Splunk Enterprise, Wazuh and FortiSIEM are considered to explain how these indicators could be correlated and escalated to a Computer Security Incident Response Team (CSIRT).

Due to the potential impact on customer transaction systems, financial applications, inventory operations and internal enterprise services, the incident is classified as a Priority 1 – Critical Security Incident within the scenario.

The assessment considers the possible operational, financial, reputational, compliance and data security consequences of ransomware. It also examines critical business assets, threat scenarios, vulnerabilities, qualitative risk levels and business continuity requirements.

The report proposes improvements in security monitoring, endpoint protection, identity and access management, network segmentation, employee awareness, incident response and cybersecurity governance.

From a business analytics perspective, this case study demonstrates how technical security indicators can be translated into enterprise risk priorities and management recommendations. It highlights the importance of connecting cybersecurity operations with business continuity, executive decision-making and organisational resilience.

Scenario limitation: All incident activities, alerts, severity classifications and business impacts described in this report are hypothetical. They are not verified findings from a real organisation or live SOC investigation.

---

1. INTRODUCTION

1.1 Background of Enterprise Cybersecurity

Organisations increasingly depend on digital systems to manage business operations, customer information, financial transactions and communication. This dependence creates opportunities for growth and efficiency but also increases exposure to cybersecurity threats.

Ransomware is a significant cybersecurity concern because it can restrict access to systems and information by encrypting files or disrupting essential services. Such incidents may affect business operations, create recovery expenses, damage customer confidence and introduce legal or regulatory concerns.

Enterprise cybersecurity therefore requires more than technical protection. Organisations need effective monitoring, incident response, risk assessment, business continuity planning and management oversight.

1.2 Overview of Ransomware Threats

Ransomware attacks may involve several stages, including phishing-based initial access, malicious code execution, credential compromise, privilege escalation, lateral movement and data encryption.

An attack that begins with one compromised employee endpoint may potentially spread to other systems if appropriate security controls are not in place.

The consequences may extend beyond information technology. Critical business functions such as payment processing, online sales, financial operations, inventory management and customer support may also be affected.

1.3 Purpose of the Case Study

The purpose of this case study is to examine a hypothetical enterprise ransomware incident from both a cybersecurity operations perspective and a business risk management perspective.

It uses a fictional retail organisation to demonstrate how security monitoring concepts, incident response processes, risk assessment and business impact analysis can support organisational decision-making.

1.4 Objectives of the Study

The main objectives are:

1. To examine a simulated ransomware attack and its possible progression within an enterprise environment.
2. To understand how SIEM-based monitoring can support threat detection and incident escalation.
3. To explain incident classification and severity assessment.
4. To identify critical business assets, threats and vulnerabilities.
5. To assess potential operational, financial, reputational and compliance impacts.
6. To examine CSIRT response, containment, eradication and recovery processes.
7. To map the hypothetical attack activities to the Cyber Kill Chain and MITRE ATT&CK frameworks.
8. To recommend risk-based security improvements and governance practices.

1.5 Scope and Limitations

The case study focuses on a hypothetical ransomware incident affecting a fictional multinational retail and e-commerce organisation.

The scope includes security monitoring concepts, incident response workflows, enterprise risk assessment, business impact analysis, cybersecurity recommendations and organisational learning.

The study is limited by its simulated nature. It does not use verified enterprise security logs, actual forensic evidence, confirmed financial loss figures or a real incident response investigation. Qualitative ratings and scenario details are illustrative and are used to demonstrate analytical methods.

---

2. COMPANY OVERVIEW

2.1 Organisation Profile

NovaMart Global is a fictional multinational retail and e-commerce organisation operating across North America, Europe and the Asia-Pacific region. Its business activities include online sales, payment processing, inventory management, warehouse operations and customer support.

For this hypothetical case study, the organisation is assumed to employ more than 15,000 people and process a high volume of customer transactions each year.

The organisation relies on a hybrid technology environment comprising cloud services, on-premises infrastructure and remote-access capabilities. Key business systems include customer-facing e-commerce platforms, payment and financial applications, inventory and warehouse systems, employee endpoints and shared enterprise services.

The availability, confidentiality and integrity of these systems are important to daily operations and customer trust.

2.2 Cybersecurity Operating Environment

In the scenario, NovaMart Global maintains security operations functions responsible for monitoring technology environments, reviewing security alerts and coordinating responses to suspected threats.

The Security Operations Center (SOC) is described as the first operational point for identifying and triaging suspicious activity. A Computer Security Incident Response Team (CSIRT) coordinates the broader response to significant incidents, including containment, investigation, recovery and communication with relevant stakeholders.

The case study refers to the following security technologies and capabilities as part of its illustrative operating model:

- **Splunk Enterprise:** Centralised log search, event analysis and security alert correlation.
- **Wazuh:** Endpoint monitoring, security event collection and host-based detection.
- **FortiSIEM:** Security information and event management concepts for monitoring and event correlation.
- **Endpoint Detection and Response (EDR):** Endpoint visibility, investigation and containment capabilities.
- **Network security controls:** Firewall, VPN and intrusion detection/prevention monitoring.

These technologies are discussed as examples within the scenario and are not presented as tools deployed or tested by the project author.

2.3 Business and Security Context

As a retail and e-commerce organisation, NovaMart Global depends on the continuous operation of digital services and the protection of customer, payment, financial and operational information.

Ransomware, phishing, credential compromise and unauthorised access could therefore affect more than technical infrastructure. Such events may interrupt sales and fulfilment, delay financial processes, increase recovery costs, affect customer confidence and create potential legal or regulatory obligations.

This organisational context provides the basis for examining the hypothetical ransomware incident from both a security operations perspective and an enterprise risk perspective. It also explains why the response must consider business priorities, service continuity and stakeholder communication alongside technical containment and recovery.

Scenario note: NovaMart Global, its workforce size, technology environment, teams and operating arrangements are fictional assumptions created for this educational case study.

---

3. INCIDENT OVERVIEW

3.1 Incident Description

On 14 March 2026, NovaMart Global is assumed to experience a ransomware incident targeting customer-facing retail infrastructure and internal enterprise systems.

The simulated attack begins when an employee in the Finance department opens a malicious invoice attachment received through email. The attachment is assumed to initiate unauthorised code execution on the employee's endpoint.

Following the initial access, the scenario progresses through suspicious PowerShell activity, possible credential compromise, privilege escalation and lateral movement across internal systems.

As the activity expands, the attacker is assumed to attempt access to shared enterprise resources and communicate with external infrastructure. Ransomware-related file encryption subsequently affects systems supporting business transactions, financial operations, inventory management and internal collaboration.

These activities create potential disruption to essential business services and increase the organisation's exposure to operational, financial, reputational and compliance risks.

3.2 Detection and Escalation

The hypothetical SOC identifies several suspicious indicators through security monitoring and log analysis.

The indicators include:

- Unusual PowerShell execution.
- Repeated authentication failures.
- Suspicious administrative access activity.
- Unexpected communication with external IP addresses.
- Unusual internal authentication and network activity.
- High-volume file modification consistent with ransomware behaviour.

The scenario uses Splunk Enterprise, Wazuh and FortiSIEM as examples of technologies that could support centralised monitoring, event correlation and investigation.

After reviewing the indicators and considering the potential impact on critical business systems, the SOC escalates the incident to the CSIRT for coordinated investigation and response.

3.3 Incident Classification and Business Impact

Within the scenario, the incident is classified as a **Priority 1 – Critical Security Incident** because of the potential compromise of business-critical systems and the possibility of widespread operational disruption.

The main areas of potential business impact include:

- **Operational:** Disruption to customer transactions, inventory processing and internal business services.
- **Financial:** Potential revenue loss, incident response expenses and system recovery costs.
- **Reputational:** Reduced customer confidence and concerns about information security.
- **Compliance:** Potential data protection, breach notification and regulatory obligations.
- **Business continuity:** Risk of prolonged interruption to essential business operations.

The classification is based on the hypothetical severity assessment within this case study. It is not an actual organisational incident record.

3.4 Initial Response Priorities

The initial response priorities in the scenario are to:

1. Validate suspicious alerts and identify potentially compromised systems.
2. Isolate affected endpoints where necessary.
3. Protect privileged accounts and reset potentially compromised credentials.
4. Assess possible ransomware propagation across the internal network.
5. Protect backup infrastructure and critical business services.
6. Escalate the incident to the CSIRT and relevant management stakeholders.
7. Prioritise business continuity and recovery requirements.

The response should balance rapid containment with the need to preserve evidence, maintain essential services and coordinate communication across technical and business teams.

Scenario limitation: The incident date, attack sequence, indicators, affected systems and response priorities are hypothetical elements created for analytical demonstration. No real breach or verified investigation is claimed.

---

4. INITIAL DETECTION AND SECURITY MONITORING

4.1 SIEM-Based Threat Detection

In the hypothetical NovaMart Global scenario, the ransomware incident is identified through suspicious security events that require investigation.

A Security Information and Event Management (SIEM) system can collect and correlate information from different sources, including endpoints, servers, firewalls and network devices. This helps security analysts identify unusual activity and investigate possible threats.

The case study considers Splunk Enterprise, Wazuh and FortiSIEM as examples of technologies that could support this monitoring process.

The simulated indicators include unusual PowerShell execution, repeated authentication failures, suspicious outbound communication and high-volume file modifications. These indicators may suggest malicious activity and require further investigation before an incident is confirmed.

4.2 Initial Indicators of Compromise (IOCs)

The following table presents illustrative indicators associated with the hypothetical ransomware scenario.

Security Indicator	Illustrative Activity	Potential Risk
Unauthorized PowerShell execution	Suspicious command-line activity on an employee endpoint	Malware execution
Repeated authentication failures	Multiple failed login attempts involving privileged accounts	Credential compromise
Privilege escalation attempts	Unusual administrative access requests	Unauthorized elevated access
Suspicious outbound connections	Communication with unknown external IP addresses	Possible command-and-control activity
High-volume file modification	Rapid modification or encryption of shared files	Ransomware deployment

Lateral movement activity	Unexpected remote authentication between internal systems	Enterprise-wide propagation

These indicators are not independently verified logs or forensic evidence. They are scenario-based examples used to explain how a SOC could investigate ransomware-related activity.

4.3 Security Monitoring and Log Analysis

A structured monitoring process helps analysts understand the nature and possible extent of a security incident.

Within the scenario, the SOC would review relevant information from:

- Windows event logs.
- Firewall and VPN logs.
- Endpoint security alerts.
- User and administrator activity logs.
- Network traffic records.
- SIEM correlation events.

The purpose of reviewing these sources is to identify unusual authentication patterns, suspicious command execution, unexpected communication and possible movement between internal systems.

Correlating events from multiple sources can provide a more complete picture than reviewing individual alerts in isolation.

4.4 Incident Escalation Workflow

The hypothetical escalation process follows these stages:

1. The SOC validates the alert and performs initial triage.
2. Analysts assess the potential threat severity.
3. Related security events are correlated.
4. Potentially compromised endpoints and accounts are identified.
5. The incident classification is reviewed.
6. The CSIRT and relevant management stakeholders are notified.

The incident is escalated because of its potential impact on business-critical systems and the possibility of ransomware propagation.

Key detection challenges

The scenario also highlights common operational challenges:

- Large volumes of security logs.
- False-positive alerts.
- Limited visibility into encrypted network traffic.
- Difficulty identifying lateral movement.
- Time pressure during containment.

Effective monitoring requires appropriate alert prioritisation, endpoint visibility, event correlation and coordination between security teams.

Scenario limitation: All alerts, indicators and monitoring activities in this section are illustrative. No live SIEM data or actual security logs were collected.

---

5. INCIDENT CLASSIFICATION AND SEVERITY ASSESSMENT

5.1 Incident Classification

Following the hypothetical initial investigation, the ransomware incident is classified as:

Priority 1 – Critical Security Incident

This classification is based on the potential impact on business-critical systems, possible compromise of sensitive information and the risk of widespread operational disruption.

5.2 Severity Assessment Process

The SOC, with support from the CSIRT, would assess the incident using technical and business-related factors.

The main assessment factors include:

- Extent of system compromise.
- Criticality of affected business assets.
- Impact on daily operations.
- Possibility of data exposure or exfiltration.
- Potential duration of system downtime.
- Threat actor persistence and activity.
- Risk of ransomware spreading across internal systems.

Considering both technical severity and business impact helps management determine the urgency of containment and recovery actions.

5.3 Factors Contributing to Critical Severity

A. Business-Critical System Impact

The hypothetical attack may affect the following systems:

- Customer transaction systems.
- Financial processing applications.
- Inventory management systems.
- Shared enterprise file systems.
- Enterprise collaboration applications.

Disruption to these systems could affect sales, payments, logistics, employee productivity and customer services.

B. Indicators of Advanced Threat Activity

The scenario includes several indicators associated with a potentially serious ransomware operation:

- Unauthorized PowerShell execution.
- Possible credential compromise.
- Privilege escalation attempts.
- Lateral movement across internal systems.
- Suspicious external communication.
- Coordinated file encryption behaviour.

These activities indicate the need for further investigation and rapid response.

C. Elevated Business Risk Exposure

Risk Category	Illustrative Impact Level	Potential Business Impact
Operational Risk	Critical	Disruption of customer and internal operations
Financial Risk	Critical	Revenue loss, recovery expenses and downtime costs
Reputational Risk	High	Customer trust and brand reputation concerns
Compliance Risk	High	Potential regulatory and legal obligations
Data Security Risk	Critical	Possible exposure of enterprise information
Business Continuity Risk	Critical	Risk of prolonged service interruption

5.4 Incident Escalation and Response Coordination

The incident requires coordination among multiple functions within the hypothetical organisation:

- Security Operations Center (SOC).
- Computer Security Incident Response Team (CSIRT).
- Network security teams.
- Infrastructure and server operations.
- Legal and compliance teams.
- Executive leadership.
- Business continuity stakeholders.

Clear responsibilities and timely communication help reduce delays during investigation, containment and recovery.

5.5 Operational Challenges During Severity Assessment

Several challenges may affect the accuracy and speed of severity assessment:

- Large volumes of security events.
- Complex alert correlation.
- Limited visibility into encrypted communications.
- Rapid lateral movement.
- Time-sensitive containment requirements.
- Dependencies between interconnected business systems.

These challenges highlight the need for consistent severity criteria, centralised monitoring and coordinated incident response procedures.

5.6 Executive Risk Perspective

From an executive risk management perspective, a ransomware incident can quickly develop from a technical security issue into an enterprise-level business risk.

The scenario demonstrates the importance of:

- Continuous security monitoring.
- Rapid incident escalation.
- Cross-functional response coordination.
- Business continuity planning.
- Risk-based cybersecurity governance.
- Executive-level cybersecurity decision-making.

Scenario limitation: The Priority 1 classification, severity factors, affected systems and impact ratings are illustrative assessments for the fictional NovaMart Global scenario. They are not verified organisational findings.

---

6. RISK ASSESSMENT AND BUSINESS IMPACT ANALYSIS

6.1 Critical Asset Identification

A risk assessment begins by identifying the assets that are important to business operations and customer services.

For the hypothetical NovaMart Global scenario, the following systems are considered critical:

Critical Asset	Business Function	Illustrative Risk Level
Customer Payment Systems	Revenue generation and transaction processing	Critical
E-Commerce Platform	Customer operations and online sales	Critical
Financial Applications	Enterprise financial management	Critical
Inventory Management Systems	Supply chain and logistics coordination	High
Active Directory Infrastructure	Enterprise authentication and access management	High
Employee Endpoints	Daily operational activities	High
Shared File Servers	Internal document storage and collaboration	High
SIEM Infrastructure	Security monitoring and threat visibility	Medium

Customer payment systems and financial applications receive the highest priority because of their close relationship with revenue generation and business continuity.

6.2 Threat Identification and Analysis

The scenario includes several threat categories that could affect the organisation.

Threat Category	Description	Potential Business Impact
Ransomware Deployment	Encryption of enterprise systems and files	Operational shutdown
Phishing-Based Initial Access	Execution of a malicious email attachment	Credential compromise
Privilege Escalation	Unauthorized administrative access	Enterprise-wide compromise
Lateral Movement	Internal propagation across systems	Expanded operational disruption
Credential Compromise	Possible theft or misuse of user credentials	Unauthorized access
Data Exfiltration	Potential theft of enterprise information	Compliance and reputational impact
Persistence Mechanisms	Continued unauthorized access	Re-infection and long-term compromise

The analysis considers how these threats could increase business disruption and create pressure on the organisation to restore essential services.

6.3 Vulnerability Assessment

The hypothetical assessment identifies several weaknesses that could increase ransomware exposure.

Identified Vulnerability	Associated Risk
Limited advanced email filtering	Increased phishing success probability
Inadequate endpoint visibility	Delayed threat detection
Weak privileged access management	Elevated lateral movement risk
Insufficient employee awareness	Increased social engineering exposure
Delayed patch management	Exploitable vulnerabilities in enterprise systems
Limited network segmentation	Faster ransomware propagation
High dependency on interconnected infrastructure	Increased operational disruption

These weaknesses indicate the importance of strengthening preventive controls, improving endpoint monitoring and increasing employee cybersecurity awareness.

6.4 Qualitative Likelihood Assessment

Likelihood assessment considers how plausible each threat scenario may be, based on the hypothetical security environment and the assumed weaknesses.

Threat Scenario	Illustrative Likelihood
Phishing-Based Attacks	High
Credential Compromise	High
Privilege Escalation Activity	High

Data Exfiltration Attempts	Medium to High
Ransomware Propagation	Critical
Business Service Disruption	Critical
Insider-Assisted Threat Activity	Medium

These qualitative ratings are used to demonstrate prioritisation. They are not statistical probabilities or predictions based on measured incident data.

6.5 Business Impact Analysis

The ransomware scenario may affect the organisation across operational, financial, reputational and compliance dimensions.

A. Operational Impact

Business Function	Potential Operational Impact
Online Retail Services	Service disruption and transaction delays
Warehouse Logistics	Delayed inventory processing
Financial Operations	Payment processing interruptions
Internal Collaboration Systems	Restricted employee communication
Customer Support Services	Reduced operational availability

Operational disruption could affect the organisation's ability to maintain normal business functions and provide continuous customer services.

B. Financial Impact

Financial Risk Area	Illustrative Impact
Revenue Loss from Downtime	High
Incident Response Expenses	High
System Recovery Costs	High
Business Interruption Costs	Medium to High
Potential Regulatory Penalties	Medium
Infrastructure Restoration Costs	High

Downtime and recovery activities may create significant financial pressure. No actual monetary loss is calculated or claimed in this case study.

C. Reputational Impact

Reputational Risk Area	Illustrative Impact
Customer Trust	High
Brand Reputation	High
Stakeholder Confidence	Medium to High
Public Perception of Security Posture	High

A cybersecurity incident may increase customer concerns about data protection and the organisation's ability to maintain reliable services.

D. Compliance and Legal Impact

Compliance Area	Illustrative Risk Level
Customer Data Protection Obligations	High
Breach Notification Requirements	High
Legal Investigation Exposure	Medium
Regulatory Review and Audit Risk	Medium to High

The organisation would need to assess whether any data was exposed and determine whether legal, regulatory or customer notification obligations apply. These obligations would depend on the actual facts and applicable laws.

6.6 Risk Scoring Matrix

The following matrix demonstrates qualitative risk prioritisation based on likelihood and business impact.

Risk Scenario	Likelihood	Business Impact	Overall Risk Level
Enterprise Ransomware Propagation	Critical	Critical	Critical
Data Theft and Exposure	High	Critical	Critical
Operational Service Downtime	Critical	High	Critical
Privileged Account Compromise	High	High	High
Phishing Recurrence	High	Medium	High
Compliance Violations	Medium	High	Medium to High

The assessment uses qualitative categories rather than a numerical probability model. Its purpose is to help management distinguish immediate risks from those requiring planned improvement.

6.7 Risk Prioritisation

Based on the illustrative assessment, the organisation's response priorities can be grouped into three stages.

Immediate Priorities

- Contain ransomware propagation.
- Isolate compromised systems.
- Disable potentially affected user accounts.
- Protect backup infrastructure.
- Restore priority customer-facing services.

Short-Term Priorities

- Conduct forensic investigation.
- Validate system integrity.
- Restore business-critical applications.

- Improve security monitoring visibility.
- Strengthen access control monitoring.

Long-Term Priorities

- Enhance phishing defence capabilities.
- Improve network segmentation.
- Strengthen privileged access management.
- Expand SIEM correlation and detection rules.
- Increase employee cybersecurity awareness.
- Improve business continuity and resilience planning.

6.8 Strategic Risk Mitigation Recommendations

Recommendation	Security Objective
Multi-Factor Authentication (MFA)	Reduce credential compromise risk
Enhanced SIEM Correlation Rules	Improve early threat detection
Endpoint Detection and Response Expansion	Strengthen endpoint visibility
Network Segmentation	Limit ransomware propagation
Security Awareness Training	Reduce phishing success rates
Backup Isolation and Recovery Testing	Improve operational resilience
Threat Hunting Programme	Identify hidden attacker activity
Zero Trust Security Principles	Strengthen enterprise access control

Sustained resilience requires cybersecurity operations to be aligned with business continuity plans, executive risk management and enterprise security governance.

Assessment limitation: Asset criticality, threat likelihood, impact ratings and risk priorities are hypothetical and qualitative. They do not represent measured probabilities, confirmed financial losses or verified findings from a real organisation.

---

7. CSIRT RESPONSE AND INCIDENT WORKFLOW

7.1 CSIRT Activation and Incident Escalation

Following the identification of suspicious security activity, the SOC would initiate the incident escalation process according to the hypothetical NovaMart Global Incident Response Plan.

The incident would be escalated to the Computer Security Incident Response Team (CSIRT) based on the following factors:

- Increasing scope of potential compromise.
- Indicators of ransomware propagation.
- Possible compromise of privileged accounts.
- Potential disruption to business-critical systems.
- Increasing enterprise risk exposure.

The CSIRT would coordinate the response with:

- SOC analysts.

- Network security teams.
- Infrastructure and server operations.
- Legal and compliance teams.
- Executive leadership.
- Business continuity stakeholders.

The purpose of this coordination is to ensure that technical containment, business recovery and stakeholder communication are managed together.

7.2 Incident Investigation Workflow

Once the incident is escalated, the CSIRT would follow a structured investigation process to understand its scope, severity and possible business impact.

The proposed investigation workflow includes:

1. Validate SIEM-generated alerts.
2. Identify potentially affected systems and accounts.
3. Review abnormal authentication attempts.
4. Examine suspicious PowerShell execution records.
5. Investigate possible lateral movement.
6. Correlate unusual network traffic.
7. Assess endpoint compromise indicators.
8. Examine unusual file modification and encryption activity.

Security monitoring technologies such as Splunk Enterprise, Wazuh and FortiSIEM are discussed as illustrative tools that could support this process.

The investigation would focus on understanding the possible attack path, identifying affected assets and determining the appropriate containment priorities.

7.3 Containment Actions

Containment aims to prevent further spread of ransomware and reduce the impact on business-critical systems.

The proposed containment actions include:

- Isolating potentially compromised endpoints from the enterprise network.
- Disabling affected user and administrator accounts.
- Blocking confirmed malicious IP addresses and domains.
- Restricting unnecessary remote access.
- Segmenting affected network infrastructure.
- Temporarily disabling compromised shared services where necessary.
- Strengthening firewall rules and SIEM monitoring.
- Using EDR capabilities to investigate and isolate affected endpoints.

Containment decisions should consider:

- Criticality of business systems.
- Operational dependencies.
- Risk of further propagation.
- Customer impact.
- Recovery complexity.

The organisation should balance rapid containment with the need to maintain essential business services and preserve relevant investigation evidence.

7.4 Eradication and Recovery Process

After containment, eradication and recovery activities would focus on removing malicious components and restoring affected systems.

Eradication activities

- Remove malicious files and persistence mechanisms.
- Reset potentially compromised credentials.
- Validate malware indicators.
- Reimage affected endpoints where required.
- Apply security patches and remediate vulnerabilities.
- Review system configurations.
- Verify backup integrity.

Recovery activities

- Restore customer transaction systems.
- Recover financial applications.
- Restore inventory and warehouse systems.
- Re-establish enterprise authentication services.
- Restore internal communication infrastructure.
- Monitor systems for possible reinfection.

Recovery should follow business priorities and should only reconnect systems after appropriate security validation.

7.5 Communication and Stakeholder Coordination

Effective communication is essential throughout incident response.

The CSIRT should coordinate with executive leadership, security operations, IT infrastructure, legal and compliance teams, business continuity teams and customer support functions.

Executive leadership should receive structured updates covering:

- Incident classification and severity.
- Potential operational impact.
- Affected business services.
- Containment and recovery progress.
- Business continuity risks.
- Potential regulatory obligations.
- Recovery priorities and estimated timelines, where supportable.

Legal and compliance teams should assess possible data exposure and determine whether notification or reporting obligations apply.

Controlled communication helps reduce misinformation and supports coordinated decision-making.

7.6 Business Continuity and Recovery Support

The scenario demonstrates the importance of maintaining essential business operations during cybersecurity recovery.

Business continuity priorities may include:

- Protecting core customer services.
- Maintaining essential operational processes.
- Minimising business disruption.
- Supporting workforce continuity.
- Maintaining customer transaction capabilities.
- Protecting critical revenue-generating services.

Recovery priorities should be determined by:

- Business criticality of each service.
- Customer and operational dependencies.
- Financial risk exposure.
- Compliance requirements.
- Recovery resources and technical complexity.

Cybersecurity incident response should therefore be integrated with business continuity planning and enterprise risk management.

7.7 Post-Incident Review and Lessons Learned

After recovery, the organisation should conduct a structured review to identify improvement opportunities.

The review should examine:

- Incident detection and escalation effectiveness.
- CSIRT coordination and response timelines.
- Containment and recovery decisions.
- Backup and restoration readiness.
- Privileged access controls.
- Employee awareness and reporting.
- Communication and management oversight.

The findings should be translated into measurable improvement actions, assigned responsibilities and review timelines.

Scenario limitation: This section describes a proposed CSIRT workflow. It does not claim that an actual CSIRT was activated, forensic investigation was performed, or containment and recovery actions were completed in a real organisation.

---

8. CYBER KILL CHAIN ANALYSIS

8.1 Introduction

The Cyber Kill Chain provides a way to understand the stages of a cyberattack, from initial reconnaissance to the achievement of the attacker's objectives.

In this hypothetical ransomware scenario, the attack is examined through its possible progression from phishing-based access to ransomware encryption and business disruption.

The analysis helps identify security weaknesses and appropriate controls at different stages of the attack lifecycle.

8.2 Attack Lifecycle Analysis

Attack Stage	Scenario Activity	Recommended Security Controls
Reconnaissance	Gathering public information and identifying employees for phishing	Security awareness, email protection and threat intelligence
Initial Access	Finance employee opens a malicious invoice attachment	Email filtering, MFA and endpoint protection
Execution	Suspicious PowerShell commands and malicious scripts	Endpoint monitoring, PowerShell logging and application control
Persistence	Possible scheduled tasks, registry changes and credential reuse	Endpoint monitoring, persistence detection and security audits
Privilege Escalation	Attempted misuse of administrative credentials	PAM, MFA and least-privilege access
Lateral Movement	Suspicious remote authentication and internal network activity	Network segmentation and internal traffic monitoring
Command and Control	Unusual outbound communication with external infrastructure	DNS monitoring, traffic analysis and outbound filtering
Actions on Objectives	Ransomware encryption of business-critical files and systems	Isolated backups, recovery testing and incident response

The attack lifecycle demonstrates how weaknesses in email security, endpoint protection, access management and network segmentation may increase the potential impact of ransomware.

8.3 MITRE ATT&CK Technique Mapping

The following table maps selected activities in the hypothetical scenario to relevant MITRE ATT&CK techniques.

Attack Activity	MITRE ATT&CK Technique	Technique ID
Phishing email delivery	Phishing	T1566
PowerShell execution	Command and Scripting Interpreter: PowerShell	T1059.001
Credential dumping	OS Credential Dumping	T1003
Privilege escalation	Exploitation for Privilege Escalation	T1068
Lateral movement	Remote Services	T1021
Command and control communication	Application Layer Protocol	T1071
Data encryption	Data Encrypted for Impact	T1486

These mappings are illustrative associations between the scenario activities and the framework. They do not establish that the corresponding techniques were observed in real security telemetry.

8.4 Analysis Summary

The Cyber Kill Chain analysis demonstrates how a ransomware attack may progress through multiple stages, beginning with social engineering and potentially ending with widespread business disruption.

The scenario highlights the importance of:

- Phishing-resistant security practices.
- Endpoint visibility and behavioural detection.
- Strong privileged access controls.
- Network segmentation.
- SIEM-based monitoring.
- Effective incident response.
- Risk-based security governance.

Mapping the hypothetical activities to MITRE ATT&CK provides a structured way to discuss attack behaviour, detection opportunities and possible defensive controls.

Scenario limitation: The attack lifecycle and MITRE ATT&CK mappings are analytical illustrations. They are not based on verified forensic evidence or actual attacker telemetry.

---

9. RISK MITIGATION RECOMMENDATIONS

9.1 Security Monitoring Improvements

NovaMart Global should strengthen its security monitoring capabilities to improve threat visibility and reduce detection delays.

Recommended actions:

- Improve SIEM correlation rules for ransomware-related activities.
- Monitor suspicious PowerShell and endpoint activities.
- Integrate threat intelligence feeds.
- Prioritise alerts based on severity and business impact.
- Monitor privileged account activities.
- Introduce proactive threat hunting.

Business benefit: Improved threat visibility, faster incident escalation and better-informed security decisions.

9.2 Endpoint and Infrastructure Security

Endpoint and infrastructure protection can reduce the likelihood of malware execution and unauthorised system access.

Recommended actions:

- Expand Endpoint Detection and Response (EDR) coverage.
- Apply regular security patches.
- Restrict unauthorised applications and scripts.
- Monitor unusual endpoint behaviour.
- Strengthen system configurations.
- Conduct regular vulnerability assessments.

Business benefit: Reduced exposure to vulnerabilities and improved protection of critical business systems.

9.3 Identity and Access Management

Strong identity controls help prevent unauthorised access and reduce the risk of privilege misuse.

Recommended actions:

- Implement Multi-Factor Authentication (MFA).
- Introduce Privileged Access Management (PAM).
- Enforce least-privilege access.
- Conduct regular access reviews.
- Monitor administrative activities.
- Apply conditional access and Zero Trust principles where appropriate.

Business benefit: Better protection of sensitive information and reduced risk of unauthorised administrative access.

9.4 Network Security

Network security controls can limit unauthorised communication and reduce the potential spread of ransomware.

Recommended actions:

- Implement network segmentation.
- Monitor internal network traffic.
- Strengthen firewall rules.
- Restrict unnecessary remote connections.
- Monitor unusual outbound communication.
- Isolate critical systems where necessary.

Business benefit: Reduced attack propagation risk and improved protection of business-critical infrastructure.

9.5 Employee Awareness and Security Culture

Since the scenario begins with a phishing email, employee awareness is an important preventive control.

Recommended actions:

- Conduct regular phishing simulation exercises.
- Provide cybersecurity awareness training.
- Educate employees about social engineering.
- Establish clear incident reporting procedures.
- Train employees to identify suspicious emails and attachments.
- Provide role-based security guidance.

Business benefit: Improved employee awareness and reduced exposure to social engineering attacks.

9.6 Incident Response and Business Continuity

An effective incident response plan helps an organisation manage security incidents while maintaining essential business operations.

Recommended actions:

- Conduct periodic CSIRT simulation exercises.
- Review and update incident response procedures.
- Test containment and recovery processes.
- Maintain isolated and validated backups.
- Establish clear executive escalation procedures.
- Regularly test business continuity and disaster recovery plans.

Business benefit: Faster recovery, reduced operational disruption and improved organisational resilience.

9.7 Strategic Security Governance

Cybersecurity should be integrated into enterprise risk management and management decision-making rather than treated only as an IT responsibility.

Recommended actions:

- Align cybersecurity practices with the NIST Cybersecurity Framework.
- Conduct periodic enterprise cyber risk assessments.
- Prepare executive-level cybersecurity reports.
- Monitor cybersecurity control effectiveness.
- Assess risks associated with third-party service providers.
- Review regulatory and compliance readiness.

Business benefit: Stronger governance, better risk prioritisation and improved accountability for cybersecurity investments.

9.8 Recommended Management Priorities

Priority	Recommended Action	Expected Business Outcome
High	MFA and privileged access controls	Reduced unauthorised access risk
High	SIEM and endpoint monitoring improvements	Better threat detection
High	Isolated backups and recovery testing	Improved business continuity
High	Network segmentation	Reduced ransomware propagation risk
Medium	Employee awareness programmes	Reduced phishing exposure
Medium	Regular risk and compliance assessments	Improved governance and accountability

Overall Recommendation

NovaMart Global should adopt a risk-based cybersecurity improvement approach that balances technical protection with operational requirements and business priorities.

Management should regularly review security risks, assign ownership for mitigation activities, monitor control effectiveness and ensure that cybersecurity investments support business continuity and organisational resilience.

Scenario limitation: These recommendations are proposed improvements for the fictional NovaMart Global case study. They do not represent controls implemented or independently tested in a real organisation.

---

10. LESSONS LEARNED

10.1 Security Monitoring and Detection

The scenario highlights the importance of centralised security monitoring and timely threat detection.

Key lessons include:

- SIEM alerts should be correlated with endpoint and network activities.
- Suspicious PowerShell execution and unusual authentication patterns require investigation.
- Monitoring lateral movement can help identify the spread of threats.
- Threat intelligence can improve detection and alert prioritisation.

10.2 Incident Response and Coordination

An effective incident response process depends on timely escalation, clear responsibilities and coordination between security teams.

Key lessons include:

- CSIRT roles and responsibilities should be clearly defined.
- Incident response procedures should be regularly reviewed.
- Automated containment can help reduce the potential spread of ransomware.
- Simulation exercises can improve organisational preparedness.
- Communication between technical teams and management is essential.

10.3 Business Continuity and Recovery

The scenario demonstrates how ransomware can disrupt business-critical systems and essential services.

Key lessons include:

- Critical business services should have recovery priorities.
- Backups should be isolated and regularly tested.
- Business continuity and disaster recovery plans should be reviewed.
- Dependencies between business systems should be identified.
- Recovery planning should consider operational and customer requirements.

10.4 Identity and Access Management

The simulated privilege escalation highlights the importance of strong identity and access controls.

Key lessons include:

- MFA should protect important user and administrative accounts.
- Privileged access should be restricted and monitored.

- Least-privilege principles should be enforced.
- Regular access reviews can identify unnecessary permissions.
- Credential compromise should be investigated promptly.

10.5 Employee Awareness and Human Risk

The phishing-based entry point demonstrates that employee awareness is an important part of cybersecurity.

Key lessons include:

- Employees need regular phishing awareness training.
- Suspicious emails and attachments should be reported promptly.
- Social engineering awareness should be strengthened.
- Security education should be relevant to employee roles.
- Technical controls should be supported by a responsible security culture.

10.6 Strategic Risk Management

Cybersecurity incidents can create consequences beyond the IT department. They may affect revenue, business continuity, customer confidence, regulatory responsibilities and organisational reputation.

Key lessons include:

- Cybersecurity should be integrated into enterprise risk management.
- Security investments should be prioritised according to business risk.
- Management should receive regular cybersecurity risk reports.
- Security maturity and third-party risks should be assessed periodically.
- Cybersecurity decisions should support long-term organisational resilience.

10.7 Overall Organisational Learning

The NovaMart Global scenario demonstrates that ransomware should be treated as both a cybersecurity threat and an enterprise business risk.

An effective resilience strategy requires coordinated security monitoring, incident response, identity protection, business continuity planning, employee awareness and executive-level governance.

Scenario limitation: These lessons are analytical conclusions drawn from a fictional ransomware case study. They do not describe verified findings from a real incident or an actual organisational review.

---

11. CONCLUSION

This case study examined a simulated ransomware incident at NovaMart Global, a fictional international retail organisation. It explored how a phishing-based attack could progress through suspicious PowerShell execution, credential compromise, privilege escalation, lateral movement and ransomware encryption.

The analysis demonstrated that ransomware is not only a technical security issue but also an enterprise business risk. A successful attack can affect critical systems, interrupt business

operations, create financial exposure, damage customer confidence and introduce regulatory and compliance concerns.

The case study highlighted the importance of:

- Centralised SIEM monitoring and effective threat detection.
- Coordinated incident response and CSIRT procedures.
- Strong identity and privileged access management.
- Endpoint protection and network segmentation.
- Isolated backups and tested recovery plans.
- Employee awareness and phishing prevention.
- Risk-based cybersecurity governance and executive reporting.

From a business analytics perspective, the case demonstrates how technical security information can be translated into risk priorities, business impact assessments and management recommendations. Connecting security indicators with operational and financial consequences helps decision-makers prioritise cybersecurity investments.

Overall, organisations should adopt a proactive and risk-based approach that integrates cybersecurity operations with enterprise risk management and business continuity planning.

Final limitation: This is an educational, hypothetical case study. The organisation, incident, alerts and response activities are simulated. No real breach, live SIEM deployment or independently verified incident investigation is claimed.

REFERENCES

The final reference list should include only the sources actually consulted and used in preparing the report. The following are appropriate primary framework sources to verify and cite if you used them:

1. MITRE. *MITRE ATT&CK Framework*. https://attack.mitre.org/
2. National Institute of Standards and Technology (NIST). *The NIST Cybersecurity Framework (CSF) 2.0*. https://www.nist.gov/cyberframework
3. National Institute of Standards and Technology (NIST). *Computer Security Incident Handling Guide*, *Special Publication 800-61 Revision 2*. https://csrc.nist.gov/pubs/sp/800/61/r2/final

Add any other books, journal articles, official guidance or product documentation that you actually consulted. Do not list sources merely because they are mentioned in the report.

APPENDICES

Include these only if the supporting material is available in your project files.

Appendix A – Illustrative Indicators of Compromise

The scenario-based indicators described in Section 4, including suspicious PowerShell execution, authentication failures, outbound communication and unusual file modification.

Appendix B – Risk Assessment Matrix

The qualitative threat likelihood, business impact and overall risk classifications presented in Section 6.

Appendix C – MITRE ATT&CK Mapping

The attack activities and corresponding technique identifiers presented in Section 8.

Appendix D – Incident Response Workflow

The proposed SOC escalation, CSIRT investigation, containment, eradication and recovery process presented in Section 7.

Appendix E – Abbreviations and Definitions

Abbreviation	Meaning
CSIRT	Computer Security Incident Response Team
SOC	Security Operations Center
SIEM	Security Information and Event Management
EDR	Endpoint Detection and Response
IOC	Indicator of Compromise
MFA	Multi-Factor Authentication
PAM	Privileged Access Management
NIST	National Institute of Standards and Technology
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques and Common Knowledge
VPN	Virtual Private Network